

I. Request

1. The Agency for Integration, Migration and Asylum (AIMA) submitted to the National Data Protection Commission (hereinafter CNPD) for opinion the Protocol for the sharing of information regarding the request for an identifier for immigrant citizens residing in Portugal. The signatories to this Protocol are the Agency for Administrative Modernization, I.P. (AMA), AIMA, the Tax and Customs Authority (AT), the Social Security Institute, I.P. (ISS), the Social Security Institute of Madeira, IP-RAM (ISSM-IP-RAM), the Social Security Institute of the Azores, I.P.R.A. (ISSA, IPRA), the Institute of Informatics, I.P. (II, I.P.), the Institute of Registries and Notaries (IRN), the Central Administration of the Health System, I.P. (ACSS), and SPMS — Shared Services of the Ministry of Health, E.P.E. (SPMS).
2. The request is accompanied by the Data Protection Impact Assessment (DPIA) which includes the following documents: Compliance Report – DPIA iAP, Agency for Administrative Modernization, I.P.; Compliance Report – PIA PMC, Agency for Administrative Modernization, I.P.; and Draft Collaboration Protocol regarding the provision of the foreign citizen identifier card in the ID.GOV application.
3. The CNPD issues this opinion within the scope of its powers and responsibilities as an independent administrative authority with the authority to oversee the processing of personal data, conferred by paragraph c) of number 1 of article 57, in conjunction with paragraph b) of number 3 of article 58, and with number 4 of article 36, all of Regulation (EU) 2016/679 of April 27, 2016 – General Data Protection Regulation (hereinafter GDPR), in conjunction with the provisions of article 3, number 2 of article 4, and paragraph a) of number 1 of article 6, all of Law No. 58/2019 of August 8, which implements the GDPR in the internal legal order.

II. Analysis

A. Protocol for the sharing of information regarding the request for an identifier for immigrant citizens residing in Portugal

4. This Protocol aims to establish the terms and conditions for the sharing of information between AMA and AIMA for the collection and transmission of data, AIMA and AT for the automatic assignment of the Tax Identification Number, between AIMA and SS/II for the automatic assignment of the Social Security Identification Number, between AIMA and SPMS/ACSS for the automatic assignment of the National User Number, and between AIMA and IRN for the purpose of record verification, through the Public Administration Interoperability Platform (iAP).
5. Decree-Law No. 41/2023 of June 2 establishes the creation of the Agency for Integration, Migration and Asylum, I.P. (AIMA), which succeeds the Immigration and Borders Service (SEF) in its administrative competencies regarding migration and asylum, and the High Commission for Migration, I.P.
6. The AT is responsible, under article 5 of Decree-Law No. 14/2013 of January 28, for the assignment of the individual Tax Identification Number (NIF), with article 9 and number 7 of article 24 of the same diploma specifying the elements that must be collected for this purpose. The coordination between AT and the other public administration bodies, particularly regarding the exchange of relevant information for the integration of taxpayer records, is defined in protocols to be established between the involved entities, under article 42 of the aforementioned diploma.
7. In turn, AMA is the entity responsible for ensuring the operationalization of the Multichannel Shared Services Platform (PMSP) and the Public Administration Interoperability Platform (iAP), which must be used as the preferred means of communication between the services and bodies of the Public Administration, under article 6 of Decree-Law No. 73/2014 of May 13, and number 7 of Resolution of the Council of Ministers No. 42/2015 of June 19. According to Decree-Law 49/2024 of August 8, AMA also has the mission to ensure the development of omnichannel service provision, which includes the Single Portal of Digital Services.
8. According to article 215 of Law No. 23/2007 of July 4, there is a duty of communication by the competent services to Social Security, the Tax and Customs Authority, and Shared Services of the

Ministry of Health, E.P.E., for the automatic assignment of the social security identification number, tax identification number, and national user number. Under number 1 of article 215 of Law No. 23/2007 of July 4, the rule applies to foreign citizens following requests for titles that regularize the situation of foreign citizens already present in the national territory.

9. Thus, there is a basis of legitimacy for this processing of personal data, under paragraph c) of number 1 of article 6 of the GDPR.

10. Conversely, the sharing of the sectoral identifier Tax Identification Number (NIF) between AT and ISS, I.P. and ACSS, for the purpose of the automatic assignment of their respective sectoral identifiers is based on the consent of the data subject.

PAR/2024/80

11. The request for consent from the data subject for these processing operations is described on page 11 of the DPIA. The consent complies with the requirements set forth in paragraph a) of number 1 of Article 6 and in Article 7 of the GDPR.

12. The data collected is adequate, relevant, and limited to what is necessary concerning the purposes described, in compliance with the principle of data minimization enshrined in paragraph c) of number 1 of Article 5 of the GDPR.

13. Number 1 of Clause 3 of the Protocol establishes that "access to information is carried out in real time, through electronic data communication between the systems of the parties, via iAP, using web services specifically implemented for this purpose, or already existing, in order to allow the provision of data."

14. The information referred to in Clause 5 is collected and sent, in an automated manner, via iAP, between the parties, with the Public Administration Interoperability Platform ensuring the conditions of privacy, confidentiality, and data security, by complying with its usage requirements. Thus, it appears that the appropriate requirements are in place to safeguard the security of communications:

PROTOCOL | No. 20/2024-AMA.

15. In turn, number 4 of Clause 3 states that the transmission of data requires prior authentication between AIMA, AMA, AT, II, I.P., and SPMS, and is only permitted to duly accredited persons in their respective systems. However, it is noted that both the Protocol and the DPIA are silent regarding the existence of a credential management policy and the maintenance of an updated list of users by each of the parties in their respective systems. Therefore, the CNPD recommends the introduction of a clause that defines the assignment of access credentials in a controlled manner through a formal management process of the respective lifecycle, as well as the review of user access rights at regular intervals.

16. It is noted that on page 3 of the document "GDPR Compliance Report / PIA Multichannel Platform (PMC)," it states that "notifications, intended for users of the Entities responsible for processing with access to the process, as well as citizens (data subjects) or representatives (...) can be sent via SMTP." This means they are sent by email. However, a large portion of malware attacks are carried out by hiding infected code in files attached to email messages. These seemingly trustworthy files, once opened, can execute arbitrary instructions on the computer and send viruses through the local network. There is also the aspect of phishing attacks, where messages contain malicious hyperlinks. By using email, there is also the risk of the message being sent to the wrong recipient. There may also be access by third parties to the mailboxes where the messages are stored, both at the destination and the origin. Thus, without the file having any access safeguard, it is considered imprudent to use email for its transmission.

17. Still in the same document, paragraph d) of section 5.1.2 indicates that the attachments associated with the forms, as well as other documents that may be uploaded during the processing of the case, are stored in a file system accessible via the NAS AMA. A NAS = Network-attached storage is a data storage connected to the network. It is not indicated whether the files are encrypted, even at rest. No mitigating measures are defined to prevent unavailability of the files against, for example, ransomware attacks. Therefore, it is necessary to ensure adequate safeguards to protect the data against loss,

corruption, unauthorized access, and other threats.

18. In turn, paragraph f) of section 5.1.2 refers to the representation of the forms in XML (eXtended Markup Language) format, which are text content files. This may mean that the submitted data is recorded in this unencrypted format. If so, there are risks to the confidentiality of the data, as well as integrity if they are editable. Measures are needed to ensure that access to this representation is restricted and it is reminded that it should not be used to store data at rest.

19. Regarding the data retention period, section 5.9 establishes that the forms are archived on AMA servers for an indefinite period. It is emphasized that this period does not align with the principle of data retention limitation provided for in paragraph e) of number 2 of Article 5 of the GDPR. It should be noted that AIMA itself in its Personal Data Protection Statement establishes that the data is "retained for the strictly necessary period" and that paragraph e) of Clause 10 of the Protocol stipulates that it is the responsibility of the data controllers to determine, within the limits of the law, the periods and conditions under which data is deleted.

20. Therefore, it is recommended that the text of the Protocol expressly clarify the data retention period in compliance with the principle of data retention limitation enshrined in paragraph e) of number 1 of Article 5 of the GDPR.

21. Under Clause 9, AIMA, AT, ISS, ISSM, IP-RAM, ISSA, IPRA, and ACSS are considered data controllers, with AMA, IRN, II, and SPMS being subcontractors, respectively.

22. On the other hand, among the obligations of the controllers provided in Clause 10, paragraph f) states "To have implemented the appropriate procedures to satisfy the rights of data subjects."

However,

PAR/2024/80

The obligation to allow the exercise of the rights of data subjects is only mentioned in Clause 8 regarding the obligations of AIMA: "(j) Ensure the exercise of rights by data subjects in accordance with the Privacy Policy, providing for this purpose the contact of the Data Protection Officer, via email: epd.protecaodedados@aima.gov.pt."

23. Now, under the terms of the GDPR, data subjects can exercise their rights with the data controllers. Not being in a situation of joint liability, such an obligation should be included in the Protocol concerning the various controllers.

24. Regarding the obligations of subcontractors, Clause 7 specifically enumerates them concerning AMA, leaving the general obligations of all subcontractors to Clause 11.

25. It should be noted that under paragraph 3 of Article 28 of the GDPR, subcontracted processing is governed by a contract or another normative act that binds the subcontractor to the data controller, establishes the object and duration of the processing, the nature and purpose of it, the type of personal data and the categories of data subjects, the obligations and rights of the data controllers, which is now specified in this Protocol.

26. However, in section 5.3 of the document titled "GDPR Compliance Report / PIA Multichannel Platform (PMC)," it states that AMA, I.P. acts as a subcontractor and carries out personal data processing activities on behalf of a data controller, in accordance with the respective protocol. Furthermore, in section 5.8.1, it is established that according to Article 28 of the GDPR, the subcontractor must cooperate with the data controller in such a way that the processing meets the requirements of the regulation and ensures the defense of the rights of the data subject. In the same section, it refers to AMA's privacy policy. It is later mentioned that this policy contains information about the contact point for access and control of personal data and the exercise of rights by data subjects. The data controller in question is AIMA. There is a lack of transparency regarding the channels that the data subject can resort to for exercising their rights within the framework of the application form for identifiers for the immigrant citizen, with the data controller. It is recommended to clarify this point in the text of the Protocol.

1 <https://www.ama.gov.pt/web/agencia-para-a-modernizacao-administrativa/politica-de-privacidade>.

PAR/2024/80

B. Protocol for the Provision of the Foreign Citizen Identifier Card in the ID.GOV Application

27. This protocol aims to define the rules regarding the provision of the foreign citizen identifier card in the ID.GOV app, with AMA and AIMA as the parties.

28. AMA is the entity responsible for the management and security of the technological infrastructure that supports the Digital Mobile Key, namely the system for generating and sending one-time and temporary numeric codes, under paragraph 8 of Article 2 of Law No. 37/2014, of June 26, in its current wording.

29. Citizens holding a Digital Mobile Key, and duly authenticated by it, can access the data contained in their documents, namely the Youth Card, through a mobile application provided by AMA (ID.GOV), whose presentation to third parties has a legal value equivalent to that of the original documents, under paragraphs 1 and 4 of Article 4-A of the aforementioned legal diploma.

30. This Protocol thus aims to allow the provision of the foreign citizen identifier card through the mobile application ID.GOV.

31. Let us then examine how the issues of data protection that the execution of this processing may raise are safeguarded, with the starting point for this purpose being the provisions in Clause 4 of the Protocol under the heading “personal data protection.”

32. Under paragraph 3 of Clause 4, AIMA is responsible for data processing and AMA is the subcontractor.

33. Under paragraph 3 of Article 28 of the GDPR, subcontracted processing is governed by a contract or another normative act under Union law or the Member States that binds the subcontractor to the data controller, establishes the object and duration of the processing, the nature and purpose of the processing, the type of personal data and the categories of data subjects, and the obligations and rights of the data controller, which this Protocol addresses.

34. Thus, the obligations of AIMA as the controller are listed in the various subparagraphs of paragraph 4 of Clause 4, and the obligations of AMA as the subcontractor in paragraph 5 of the same Clause.

35. Regarding the legal basis for data processing, Annex I indicates the exercise of functions of public interest.

36. Now, under the AIPD, the sharing of the Foreign Citizen Identification Number (NIE) with the Digital Mobile Key platform, in case the foreign citizen holds it, for the purposes of 3v.

PAR/2024/80

The association of that identifier to the platform and its use by the foreign citizen in the future for the realization of respective digital public services is based on the consent of the data subject.

37. The request for consent from the data subject for these processing operations is described on page 11 of the AIPD. The consent complies with the requirements set forth in paragraph a) of number 1 of article 6 and in article 7 of the GDPR.

38. It is important to emphasize that the use of the application presupposes the consent of the data subject for the storage and presentation of their documents in digital format. In other words, the transmission of information from AIMA to AMA should never be made without adequate guarantees that the procedure was triggered at the request of the data subject.

39. Given the obligations of AIMA and AMA, as the data controller and subcontractor, respectively, the provisions of paragraph e) of number 2 of article 5 and article 32 of the GDPR must be considered regarding the security of processing, reminding the data controller that under number 2 of the cited article 5, the exclusive responsibility to comply with and demonstrate compliance with the GDPR lies with them.

40. In Clause 2, number 2, paragraph d) it is established that AMA will provide a VPN for communication between AMA and AIMA.

41. It is recommended to implement a strong authentication system and audit logs that allow tracking the communications made, at the origin and at the destination.

IV. Conclusion

42. In accordance with the terms and grounds set forth above, CNPD recommends:

- a) The introduction of a provision that defines the assignment of access credentials in a controlled manner through a formal management process of the respective lifecycle, as well as the review of user access rights at regular intervals;
- b) The establishment of adequate safeguards to protect data against loss, corruption, unauthorized access, and other threats, as outlined in point 17;
- c) That the text of the Protocol expressly clarifies the retention period of the data in compliance with the principle of data retention limitation enshrined in paragraph e) of number 1 of article 5 of the GDPR;
- d) The clarification of the channels that the data subject can resort to for the exercise of their rights within the framework of the application form for identifiers for the immigrant citizen, with the data controller; and
- e) Regarding the second Protocol, it is recommended to implement a strong authentication system and audit logs that allow tracking the communications made, at the origin and at the destination.

Approved at the meeting on January 14, 2025

Paula Meira Lourenço (President)

Signed by: PAULA CRISTINA MEIRA LOURENÇO

Date: 2025.01.14 23:43:03+00'00'

Certified by: Diário da República

Certified attributes: President - National Data Protection Commission

4v.